

LAPORAN PRAKTIKUM VULNERABILITY ASSESSMENT (VA) MENGUNAKAN OWASP ZAP

INFORMASI PENGUJIAN

- **Tool:** OWASP ZAP (Zed Attack Proxy) v2.17.0
- **Metode:** DAST (Dynamic Application Security Testing) / Automated Web Scan
- **Target Scope:**
 1. <http://demo.testfire.net/>
 2. <http://testasp.vulnweb.com/>
 3. <https://testasp.vulnweb.com/>
- **Waktu Pengujian:** 27 Agustus 2026, 15:54:57

1. RINGKASAN EKSEKUTIF

Pengujian keamanan dinamis terhadap target menghasilkan total 17 jenis alert kerentanan. Distribusi tingkat risiko temuan mencakup:

- High: 1 jenis alert (5.9%)
- Medium: 5 jenis alert (29.4%)
- Low: 8 jenis alert (47.1%)
- Informational: 3 jenis alert (17.6%)

Berdasarkan confidence level, 70.6% temuan berstatus *Medium Confidence* dan 23.5% berstatus *High Confidence*.

2. MATRIKS STATISTIK TEMUAN

Target Site	High	Medium	Low	Informational	Total Alert Unik	Total Endpoints
http://demo.testfire.net	1	4	4	3	12	84
http://testasp.vulnweb.com	0	0	4	0	4	21

https://test asp.vulnw eb.com	0	1	0	0	1	1
-------------------------------------	---	---	---	---	---	---

3. DETAIL TEMUAN KERENTANAN UTAMA

A. Kategori High Risk

- Cross Site Scripting (DOM Based) [CWE-79 / WASC-8]
 - **Target:** http://demo.testfire.net/
 - **Tool Scanner:** Active Scanner
 - **Payload:** #jaVasCript:/*-/*\`/'"/"/(/\*oNcliCk=alert(5397))//%0D%0A%0d%0a//</stYle/</titLe/</teXtarEa/</scRipt/--!>\x3csVg/<sVg/oNloAd=alert(5397)//>\x3e`
 - **Dampak:** Penyerang dapat menyuntikkan script berbahaya pada DOM client-side yang berakibat pada pembajakan session, pencurian token/cookie, dan pengalihan kredensial pengguna.
 - **Solusi:** Lakukan kontekstual output encoding (menggunakan library terstandarisasi seperti OWASP ESAPI/Microsoft Anti-XSS) dan validasi ketat terhadap input yang berinteraksi dengan API DOM (document.location, innerHTML, document.write).

B. Kategori High Risk

- Absence of Anti-CSRF Tokens [CWE-352 / WASC-9]
 - **Target:**
http://demo.testfire.net/login.jsp
(Form: btnSubmit, passw, uid)
 - **Total Instansi:** 6
 - **Dampak:** Memungkinkan penyerang memaksa browser korban yang telah terotentikasi untuk mengeksekusi request yang tidak diinginkan.
 - **Solusi:** Terapkan anti-CSRF token (nonce) yang terikat pada session pengguna di seluruh HTTP POST/state-changing request.
- Content Security Policy (CSP) Header Not Set [CWE-693 / WASC-15]
 - **Target:**
http://demo.testfire.net/robots.txt
(Systemic across 10 endpoints)
 - **Dampak:** Tidak ada pembatasan sumber daya konten (script, style, frame) yang boleh dieksekusi oleh browser, meningkatkan risiko XSS dan data injection.
 - **Solusi:** Konfigurasi header Content-Security-Policy pada web server untuk membatasi domain asal resource yang sah.

- Missing Anti-clickjacking Header [CWE-1021 / WASC-15]
 - **Target:**
<http://demo.testfire.net/>
(Systemic across 10 endpoints)
 - **Dampak:** Halaman rentan disematkan ke dalam elemen <frame>/<iframe> situs berbahaya untuk manipulasi klik.
 - **Solusi:** Implementasikan header X-Frame-Options: SAMEORIGIN atau gunakan direktif CSP frame-ancestors.
- Sub Resource Integrity (SRI) Attribute Missing [CWE-345 / WASC-15]
 - **Target:**
http://demo.testfire.net/index.jsp?content=personal_investments.htm
 - **Evidence:**

```
<script src="http://demo-analytics.testfire.net/urchin.js" type="text/javascript"></script>
```
 - **Dampak:** Jika server pihak ketiga terkompromi, script berbahaya dapat dimuat tanpa validasi integritas.
 - **Solusi:** Tambahkan atribut integrity berbasis hash SHA (misal integrity="sha384-...") pada tag <script> eksternal.
- HTTP Only Site [CWE-311 / WASC-4]
 - **Target:**
<https://testasp.vulnweb.com/>
(Gagal negosiasi SSL/TLS, hanya melayani HTTP)
 - **Dampak:** Lalu lintas data sensitif dikirim dalam bentuk teks polos (*plaintext*) dan rentan terhadap serangan Man-in-the-Middle (MitM).
 - **Solusi:** Konfigurasi sertifikat SSL/TLS dan alihkan seluruh lalu lintas HTTP ke HTTPS secara permanen (HSTS).

C. Kategori Low & Informational Risk

- Application Error Disclosure & Debug Error Messages [CWE-550, CWE-1295]:
Ditemukan pada POST
<http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F> yang mengembalikan kode status 500 Internal Server Error.
- Server Information Leakage [CWE-497]:
 - Header Server: Apache-Coyote/1.1 pada demo.testfire.net.
 - Header Server: Microsoft-IIS/8.5 dan X-Powered-By: ASP.NET pada testasp.vulnweb.com.
- Cookie Insecurity [CWE-1004, CWE-1275]:
 - Cookie ASPSESSIONIDCCAQQDTB tidak memiliki flag HttpOnly.

- Cookie JSESSIONID tidak memiliki atribut SameSite.
- Information Disclosure via Comments [CWE-615]: Ditemukan komentar sensitif pada halaman login:
<!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->

4. RENCANA TINDAKAN REMEDIASI PRIORITAS

- a. **Prioritas 1 (Urgent):** Perbaiki kerentanan DOM-based XSS pada demo.testfire.net dan aktifkan enkripsi HTTPS secara penuh di seluruh endpoint.
- b. **Prioritas 2 (High):** Implementasikan mekanisme Anti-CSRF token pada seluruh form transaksi dan autentikasi.
- c. **Prioritas 3 (Medium):** Terapkan security headers (Content-Security-Policy, X-Frame-Options, X-Content-Type-Options: nosniff) serta tambahkan atribut HttpOnly dan SameSite=Lax/Strict pada manajemen cookie.
- d. **Prioritas 4 (Low):** Lakukan server hardening dengan menyembunyikan header versi (Server, X-Powered-By), menonaktifkan pesan error debug di mode produksi, dan menghapus komentar developer pada kode HTML.